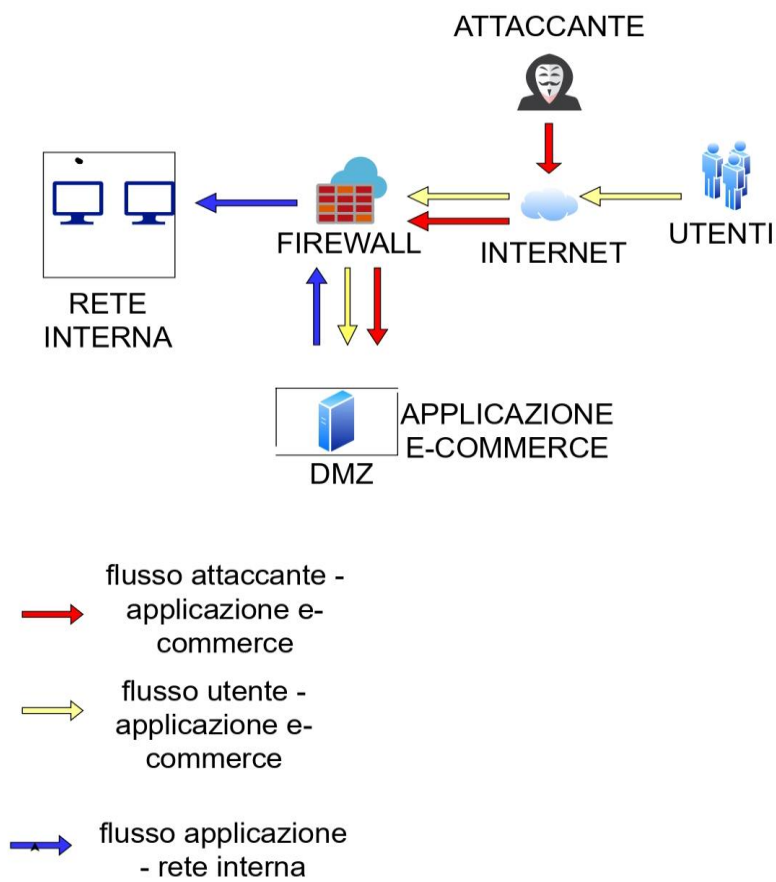


W20D4_PROGETTO 5_SECURITY OPERATION

ARCHITETTURA DI RETE

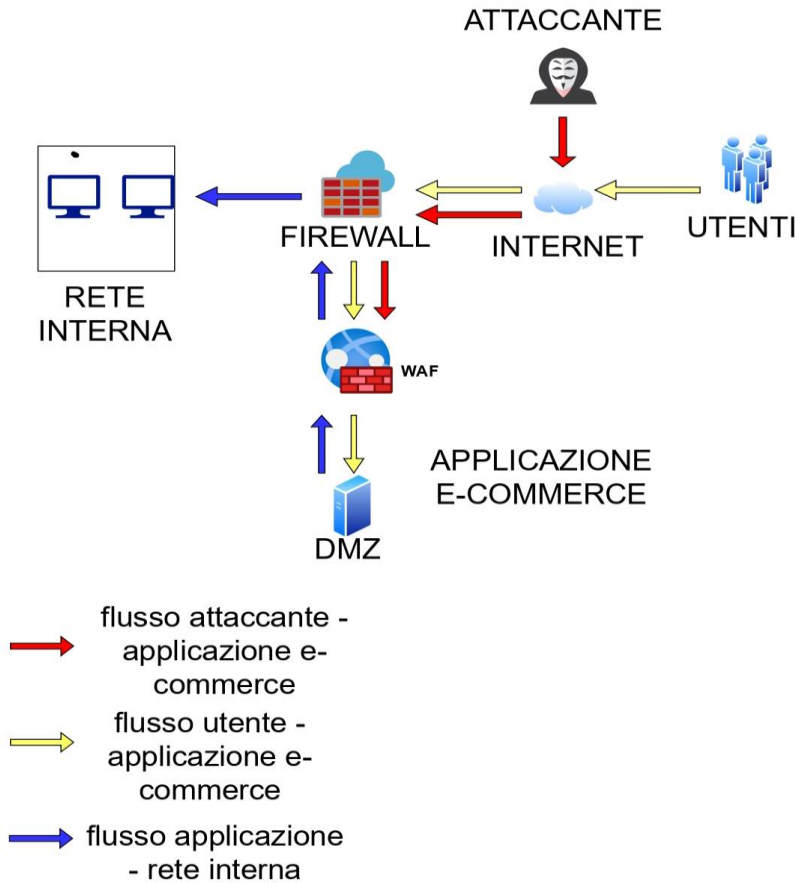


1) Quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato? Modificate la figura in modo da evidenziare le implementazioni

OBIETTIVO: prevenire attacchi che vadano a compromettere la sicurezza dei dati aziendali, della struttura e degli utenti partendo dalla protezione dell'applicazione web.

Grazie alla creazione della demilitarized zone gli utenti esterni non possono comunicare direttamente con la rete interna, questo è permesso dal firewall che si interpone tra rete interna ed esterna. Per proteggere l'applicazione e-commerce quindi il livello applicativo, si interviene con l'installazione del Web Application Firewall. Questo strumento attraverso regole di filtraggio delle richieste HTTP è in grado di bloccare e riconoscere in maniera automatizzata gli attacchi di tipo SQLi e XSS. Quando si parla di attacchi SQLi e XSS è anche necessario intervenire sulla sanitizzazione dell'input in modo da renderlo conforme alle regole di input che si creano in fase di sviluppo dell'applicazione. Grazie ai Prepared Statement l'attaccante è impossibilitato nel modificare la query in quanto il database è in grado di distinguere tra codici e dati.

ARCHITETTURA DI RETE

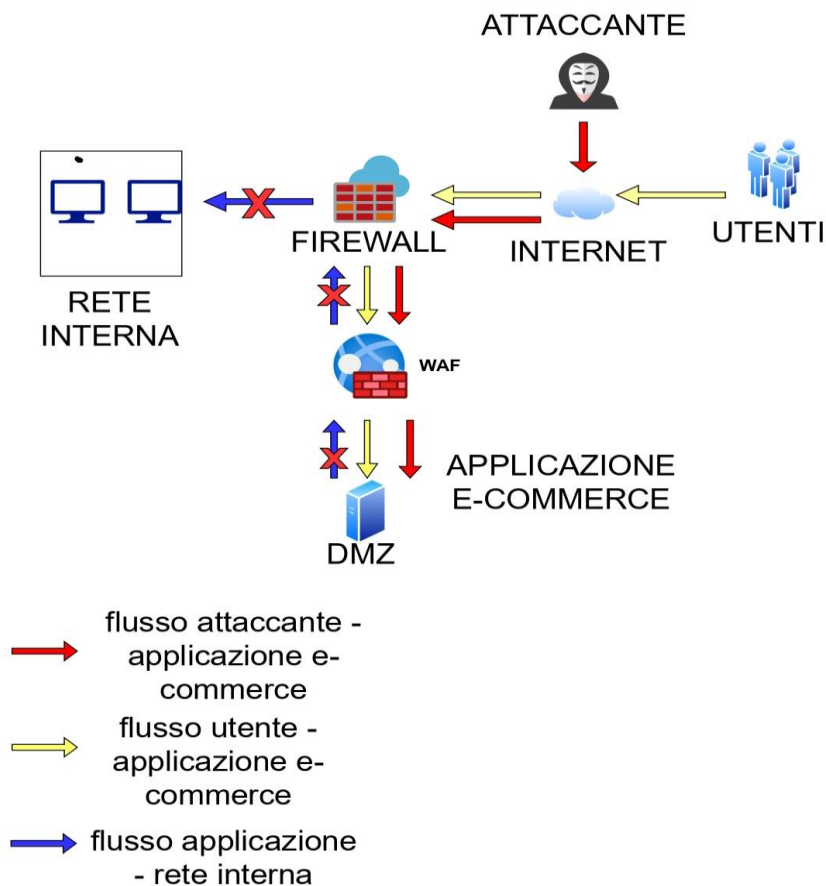


Il WAF filtra il traffico in ingresso bloccando connessioni sospette e gli attacchi SQLi e XSS. L'attaccante non ha la possibilità di compromettere la struttura aziendale.

3) L'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata.

Se l'applicazione web è infettata da un malware, per limitare danni ai sistemi e ai dati bisogna **bloccare il malware** per evitare il suo propagarsi nella rete. Più sarà rapida l'attività di limitazione dei danni meno impattante sarà la conseguenza dell'eventuale blocco operativo all'interno dell'azienda e la perdita dei dati causata. Se la rete interna non ha accesso ad internet si potrà già limitare la propagazione del malware. In questo modo si garantisce il principio di integrità e si isola l'incidente.

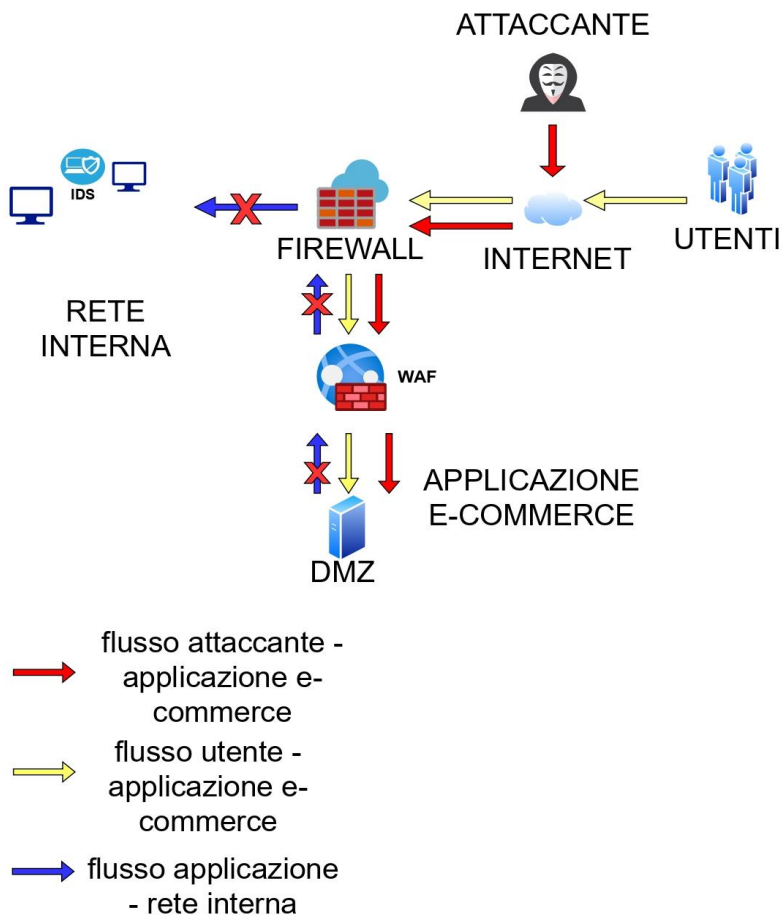
ARCHITETTURA DI RETE



Allo stesso tempo l'attaccante ha ancora accesso alla demilitarized zone. L'azienda ha optato per l'accettazione del rischio accettando il rischio residuo.

Per capire il funzionamento del malware si utilizzano strumenti di rilevazione e prevenzione delle intrusioni: IPS e IDS, dispositivi che vanno installati sulla rete. Gli Intrusion Detection System sono strumenti che controllano il traffico di sistema e nel caso di eventuali attacchi inviano delle notifiche segnalando anomalie agli amministratori di sistema. Riconoscono le anomalie di sistema grazie alle firme (LOG) lasciate dagli attacchi noti ma non intervengono per bloccare l'attacco. Questo li differenzia dagli Intrusion Prevention System, sistemi in grado sia di prevenire che intervenire in maniera automatizzata per bloccare gli attacchi. Sono dunque strumenti entrambi essenziali per effettuare un controllo continuo della rete.

ARCHITETTURA DI RETE



L'IDS è installato sulla rete interna che ospita gli applicativi critici e funge da controllore per rilevare le attività sospette.

Una volta registrato ed analizzato, il traffico può essere poi inviato al Security Information and Event Management, quel sistema che automatizza il monitoraggio grazie all'attività di correlazione.

2) Impatti sul business: l'applicazione Web subisce un attacco di tipo DDoS dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica

Se in media gli utenti spendono circa 1.500 € al minuto sulla piattaforma, la perdita economica sarà pari a 15.000 € (**BIA**) ma oltre alla perdita economica si deve considerare anche il danno reputazionale per l'azienda. Per ridurre l'impatto di attacchi come il DDoS e garantire la continuità operativa dell'azienda è fondamentale implementare e conoscere i piani di gestione. Tra questi troviamo:

Business Impact Analysis: serve per identificare attraverso l'approccio quantitativo e quello qualitativo, quali sono le probabilità che le minacce possano verificarsi e gli eventuali impatti.

Business Continuity Plan e Disaster Recovery Plan: mentre il BCP garantisce la continuità del business attraverso policy e procedure per minimizzare gli impatti negativi sull'operatività di una compagnia dopo un eventuale evento o attacco, il DRP è il documento tecnico che prevede tutti i controlli tecnici da implementare dopo l'incidente.

Incident Response Plan: è il piano operativo per reagire ad un attacco; le fasi principali sono la procedura di contenimento (**es: isolamento**), la rimozione e il recupero dell'operatività e dei servizi. Grazie a questo approccio si può anche evitare che uno stesso attacco possa accadere in futuro.

4)Modifica «più aggressiva» dell'infrastruttura (se necessario/facoltativo magari integrando soluzione al punto 2)

Si prende in considerazione il caso di un'azienda che ha a disposizione 30.000 € di budget da investire in soluzioni di sicurezza ICT per integrare il WAF e l'IDS già implementati:

PENETRATION TESTING: web application PT + PT infrastrutturale, costo dell'intervento € 13.000/anno

FORMAZIONE DEL PERSONALE: Cybersecurity Awareness Training: per 40 dipendenti con costo totale di 1000€/anno

BACKUP: NinjaOne, soluzione contro malware e backup di server, dati e endpoint . Costo €1.800/anno

FIREWALL: Utilizzo di un Next Generation Firewall che diversamente dal Packet filtering Firewall effettua una analisi completa della connessione.

Firewall Gold + Cold Standby per la configurazione ridondante € 2.290

Costo totale delle implementazioni: €18.090

Fine progetto 27/09/2026